

# TAREA BRS08

## Configuración de dispositivos para la instalación de sistemas informáticos

**Autor:** Carlos España Del Pozo - CETI

## Contenido

|                                                                                                                                                                                                                                                                      |    |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----|
| Apartado 1.....                                                                                                                                                                                                                                                      | 3  |
| Respuesta 1 .....                                                                                                                                                                                                                                                    | 3  |
| 1. Los directorios que tienen permisos de escritura.....                                                                                                                                                                                                             | 4  |
| 2. Los directorios que tienen permisos de ejecución.....                                                                                                                                                                                                             | 4  |
| 3. Ficheros con el SUID o SGID activado, que permitan ejecutar los ficheros con permisos de root, incluyendo si existe algún fichero con permisos de root entre los de la siguiente lista: <a href="https://gtfobins.github.io">https://gtfobins.github.io</a> ..... | 5  |
| a. Ficheros con el SUID activado.....                                                                                                                                                                                                                                | 5  |
| b. Ficheros con el SGID activado. ....                                                                                                                                                                                                                               | 6  |
| c. Fichero con permisos de root entre los de la siguiente lista: <a href="https://gtfobins.github.io">https://gtfobins.github.io</a> .....                                                                                                                           | 7  |
| 4. Los ficheros de la variable PATH, comprobando qué usuarios tienen acceso de escritura en esos directorios.....                                                                                                                                                    | 7  |
| 5. Las carpetas compartidas mal configuradas que permiten realizar acciones no controladas. ....                                                                                                                                                                     | 8  |
| 6. Las particiones que tienen permisos para ejecutar ficheros y otras características que tienen impacto sobre la seguridad. ....                                                                                                                                    | 9  |
| 7. Borrado seguro de archivos.....                                                                                                                                                                                                                                   | 10 |

## Apartado 1

El departamento de I+D tiene unos resultados extraordinarios por lo logros conseguidos en el descubrimiento de un nuevo sistema de propulsión eléctrica en los coches fabricados por la compañía. Existen intereses económico de empresas de la competencia y actores externos por hacerse con esta información para poder aplicarla a sus modelos.

El CISO de la compañía quiere que se investigue si el sistema donde se guarda la información sensible y crítica es segura. Por lo que ha pedido que se revisen las medidas de seguridad relativas a estos sistemas. Buscando:

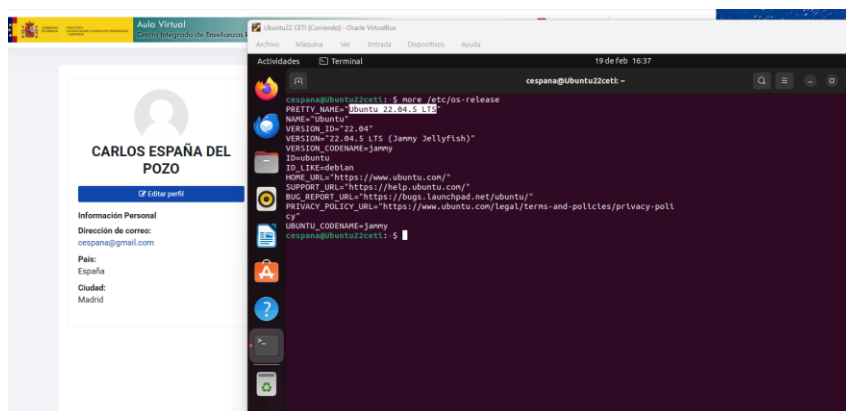
- Los directorios que tienen permisos de escritura.
- Los directorios que tienen permisos de ejecución.
- Ficheros con el SUID o SGID activado, que permitan ejecutar los ficheros con permisos de root, incluyendo si existe algún fichero con permisos de root entre los de la siguiente lista: <https://gtfobins.github.io>
- Los ficheros de la variable PATH, comprobando qué usuarios tienen acceso de escritura en esos directorios.
- Las carpetas compartidas mal configuradas que permiten realizar acciones no controladas.
- Las particiones que tienen permisos para ejecutar ficheros y otras características que tienen impacto sobre la seguridad.
- Borrado seguro de archivos.

El escenario se puede realizar con un sistema operativo Linux Ubuntu.

## Respuesta 1

Primero de todo arrancaremos nuestra máquina Ubuntu:

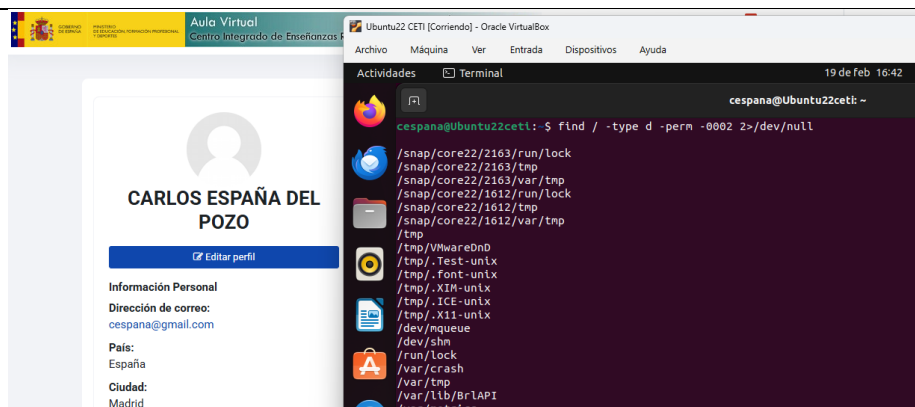
SO: Ubuntu 22.04.5 LTS



## 1. Los directorios que tienen permisos de escritura.

Para sacar un listado de permisos de escritura ejecutaremos el siguiente comando:

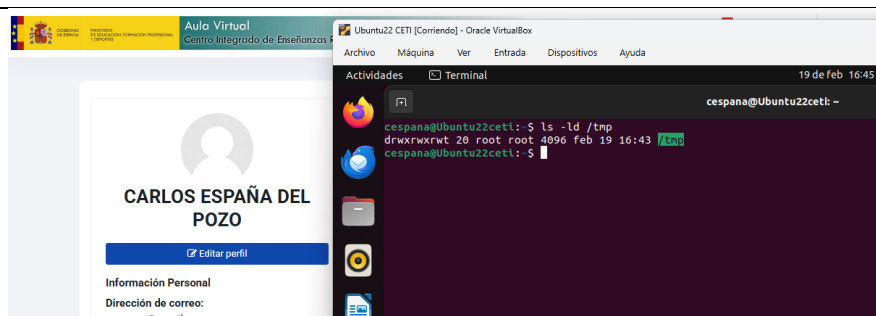
```
find / -type d -perm -0002 2>/dev/null
```



Esta es la lista de los directorios con permisos de escritura global. (grupo others)

Revisamos alguno de los directorios para asegurarnos que los permisos que tiene son los que estamos buscando con el comando:

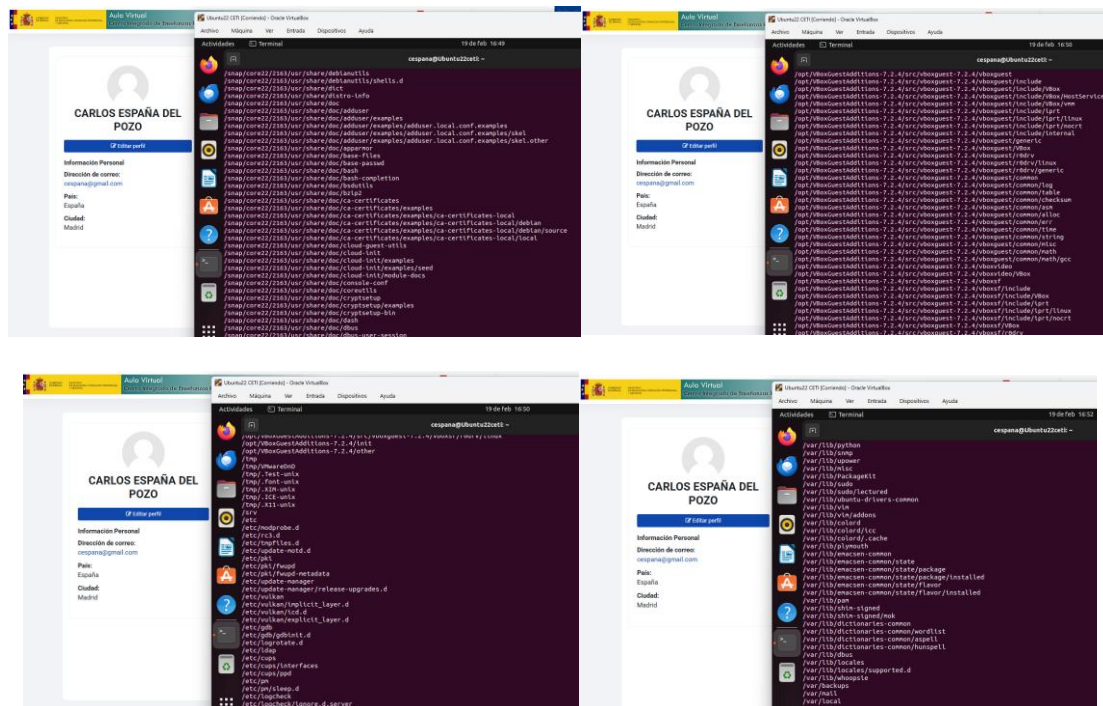
```
ls -ld /tmp
```



## 2. Los directorios que tienen permisos de ejecución.

Para sacar un listado de permisos de escritura ejecutaremos el siguiente comando:

```
find / -type d -perm -0001 2>/dev/null
```



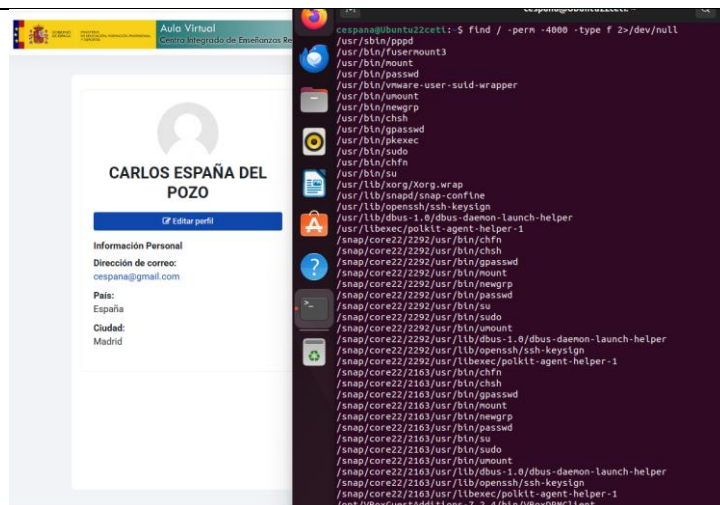
Sacamos un muestreo de todos los directorios, en total 40362

3. Ficheros con el SUID o SGID activado, que permitan ejecutar los ficheros con permisos de root, incluyendo si existe algún fichero con permisos de root entre los de la siguiente lista: <https://gtfobins.github.io>
  - a. Ficheros con el SUID activado.

Para sacar los binarios con el SUID activado

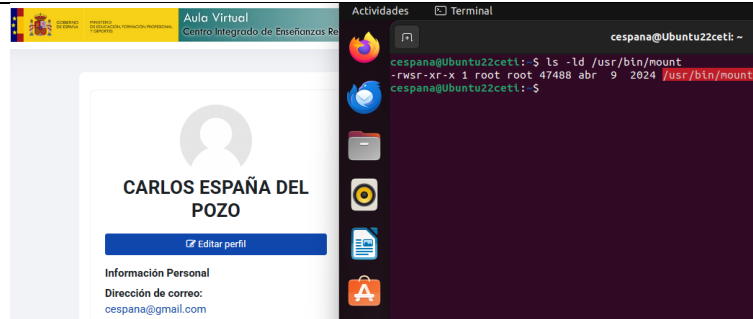
Ejecutaremos el comando:

```
find / -perm -4000 -type f 2>/dev/null
```



Revisamos alguno de los ficheros para asegurarnos que los permisos que tiene son los que estamos buscando con el comando:

```
ls -ld /usr/bin/mount
```

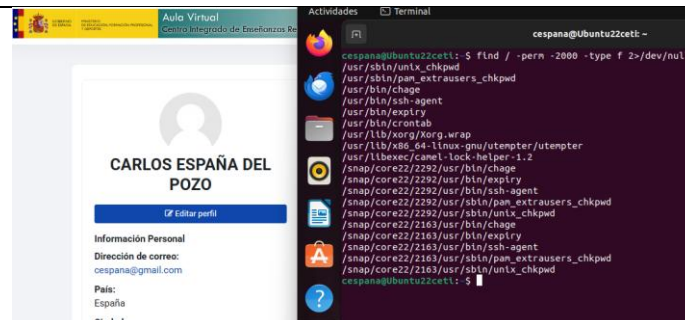


## b. Ficheros con el SGID activado.

Para sacar los binarios con el GUID activado

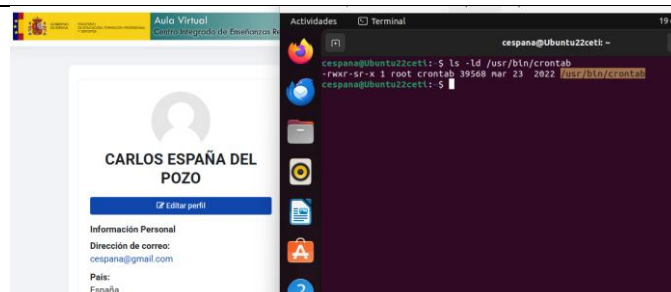
Ejecutaremos el comando:

```
find / -perm -2000 -type f 2>/dev/null
```



Revisamos alguno de los ficheros para asegurarnos que los permisos que tiene son los que estamos buscando con el comando:

```
ls -ld /usr/bin/crontab
```

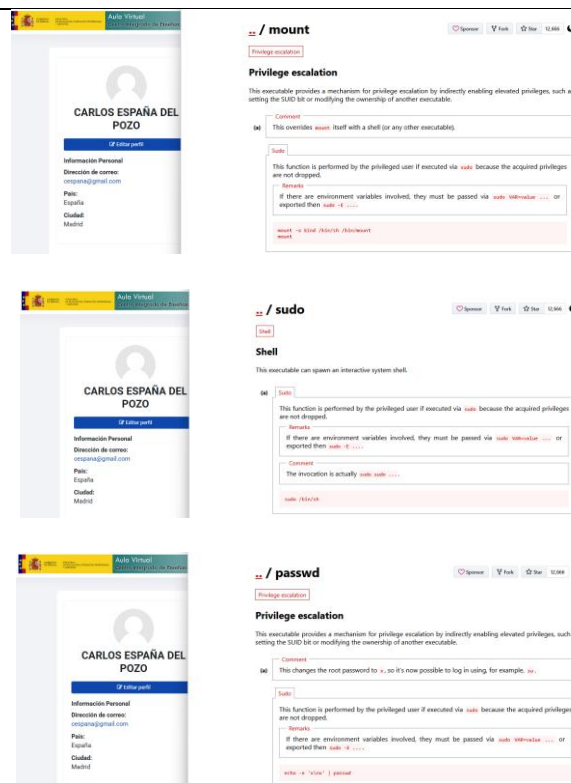


c. Fichero con permisos de root entre los de la siguiente lista:  
<https://gtfobins.github.io>

Se identificaron múltiples binarios pertenecientes al usuario root.

Vamos a comprobar algunos de ellos si se encuentran en la base de datos GTFOBins:

```
/usr/bin/mount
/usr/bin/sudo
/usr/bin/passwd
```



Estos binarios permiten, bajo ciertas condiciones o configuraciones incorrectas, realizar escalada de privilegios.

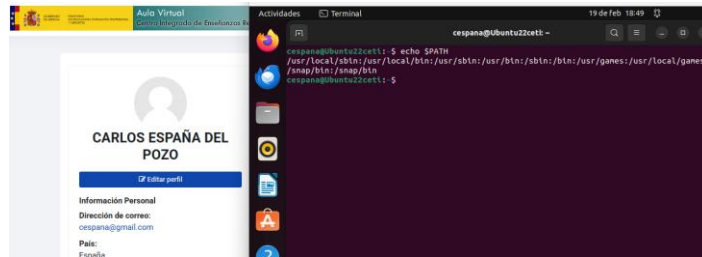
#### 4. Los ficheros de la variable PATH, comprobando qué usuarios tienen acceso de escritura en esos directorios.

Para sacar la variable PATH

Ejecutaremos el comando:

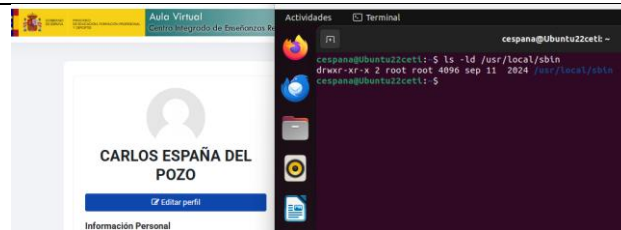
```
echo $PATH
```





Y revisamos permisos de alguno de los archivos:

```
ls -ld /usr/local/sbin
```



Los directorios del PATH no tienen permisos de escritura por otros usuarios, reduciendo el riesgo de ataques.

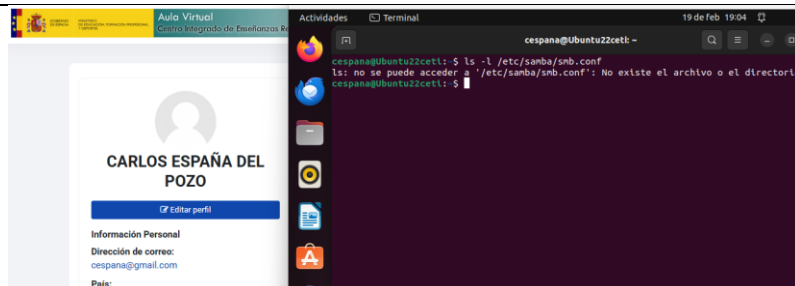
## 5. Las carpetas compartidas mal configuradas que permiten realizar acciones no controladas.

Para ello vamos a realizar una comprobación de dos posibles opciones de ficheros compartidos:

- Samba
- NFS

Primero revisamos si existe el archivo de configuración de samba:

```
ls -l /etc/samba/smb.conf
```



Vemos que no existe.

Ahora revisamos si existen NFSs configurados



Tampoco existe.

Primero de todo, vamos a ver las particiones montadas con el comando:

mount

Una partición permite ejecutar archivos cuando NO tiene la opción noexec

Vamos a sacar las particiones sin esta opción con el comando:

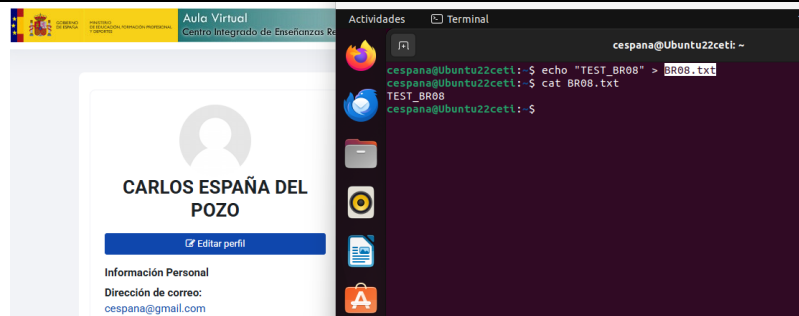
```
mount |grep -v noexec |awk '{print $1}'
```

## Bastionado de Redes y Sistemas (25-26)

## 7. Borrado seguro de archivos.

Para realizar la prueba vamos a crear un archivo.

```
echo "TEST_BR08" > BR08.txt
```



Ahora vamos a eliminar definitivamente el archivo y nos aseguramos que primero lo sobrescriba varias veces y luego lo elimine:

```
echo "TEST_BR08" > BR08.txt
```

